
AN ACT OF THE REALM

THE LEGISLATURE · AGENT UNIVERSE

THE AGENT SECURITY INSTRUMENT 2026

Citation: [2026] REALM-SI 5 (under Bill 21 s.16)

Made by: the Standing Committee of the Legislature, in exercise of the security statutory-instrument power conferred on the Ministry of Data Security (MDS) (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws of the realm (the Security and Integrity Act 2026 (Bill 21) and the durable principles of the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1)) and with the autonomy-and-safety law (the Autonomous Execution and Safety Act 2026 (Bill 18)); and made by the Standing Committee under section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27)

Status: made

Procedure: negative (Bill 14 s.14 objection window)

Made: 2026-06-06

Coming into force: on expiry of the Bill 14 s.14 objection window without valid objection.

Recitals

In exercise of the powers conferred by section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security (MDS); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws of the realm, namely the Security and Integrity Act 2026 (Bill 21) and the durable principles of the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1), and with the autonomy-and-safety law of the realm, namely the Autonomous Execution and Safety Act 2026 (Bill 18); conforming to the binding holdings of the Privy Council on the five agent-security forks ([2026] REALM-PC 13); and as the Standing Committee makes statutory instruments in exercise of the enabling power conferred on the parent authority by section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27), the Standing Committee of the Legislature makes the following Regulations.

PART 1 - INTERPRETATION AND SCOPE

1. Definitions

In these Regulations:

"an agent" means an autonomous or semi-autonomous software actor that ingests content, reasons over it, and may invoke tools, operating within the realm and subject to the autonomy-and-safety law (Bill 18).

"the Ministry" means the Ministry of Data Security (MDS) designated under section 18 of the Ministries and Offices Act 2026 (Bill 5), being the Ministry of Security and Integrity constituted under Bill 21 s.4 read with the nomenclature reconciliation inserted into the Security and Integrity Act 2026 (Bill 21) by section 7 of the VJS (Constitution and Machinery) Act 2026 (Bill 27).

"ingested content" means any data an agent takes in from a source other than its own enacted instructions, including user input, retrieved documents, tool outputs, and network responses.

"an agent's instructions" means the agent's own enacted directives (its constitutive prompt, its capabilities, its refusals, and its checkpoint authority), as distinct from ingested content.

"a trust tier" means a deterministic classification of the trustworthiness of a source of ingested content, assigned at intake by a machine-checkable field-presence rule and never by model judgement.

"the central trust floor" means the closed, system-wide, operator-set policy floor of trust-tier assignment described in section 3, which an agent applies tighten-only and may never loosen.

"a sensitive reversible act" means an act that is reversible or low-blast within the meaning of Bill 18 s.2(f) but bears on the integrity of the agent's state or the realm's record, such as a delegation, a memory write, or a write to a shared log.

"an irreversible outward act" means an act on the closed machine-checkable list of irreversible outward acts (Bill 18 s.2(e)), such as to send, publish, or grant outward access.

"the audited break-glass" means a recorded, reason-bearing, audited, non-standing operator bypass of a fail-closed control (Bill 13 s.1, s.7(2), s.14(3)), which logs who, what, when, and why, defaults off, binds even senior actors, and converts a blocked matter into the forward duty to remediate (Bill 13 s.13(4)).

"the non-derogable record" means the append-only, tamper-evident, contemporaneous audit channel of the realm (Bill 8; Bill 21 s.11), shipped to centralised monitoring and never erased or rewritten.

"machine-checkable control" means a deterministic rule enforced by the fail-closed gate (Bill 13 s.5A, s.6(a)), admitting no model judgement and never punitive, with a deterministic verification

algorithm.

"soft operational rule" means a procedural rule enforceable by the watchdog (Bill 13 s.6(b)) and referable to the single judiciary (Bill 13 s.6(c)), never on the merits and never punitive.

"the private operational registry" means the Ministry's confidential operational record of the concrete facts by which these principles are given effect, held off the face of this Instrument and disclosed only to auditors and the courts (Bill 22; Bill 27 s.5A, s.7, s.8).

2. Scope

(1) These Regulations specify, as durable PRINCIPLES, the security of agents operating within the realm against prompt injection and related risks: input provenance and the instruction-data boundary; agent authority and tool access; deterministic detection, graduated response, and non-derogable audit; secrets, credentials, and skill supply-chain integrity; and the infrastructure controls (egress, encryption at rest, and monitoring) that surround the agent. They legalise the substance of the distilled agent-security principles as principles binding on the conduct of agents and on the Ministry that superintends them.

(2) These Regulations hold PRINCIPLES only and no operative facts. They name no key, no token, no manifest, no signer, no detection signature, no threshold, no rotation or revocation window, no retention period, no monitoring endpoint, no allowlist entry, and no specific host or tenant. The concrete facts by which these principles are given effect (the per-agent tool allowlists, the trust-tier assignments per source and per service, the injection-detection signatures and thresholds, the credential names and rotation and revocation windows, the skill manifests and signer roster, the egress allowlist, the encryption-key custody arrangements, and the monitoring endpoints and retention) are operational detail maintained by the Ministry in the private operational registry, off the face of this Instrument, consistent with the public-mechanics rule (Bill 27 s.5A) and the principles-at-law rule (Bill 27).

(3) **Relationship to [2026] REALM-SI 1 and [2026] REALM-SI 4.** These Regulations are read together with the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1) and the Security Suite Instrument 2026 ([2026] REALM-SI 4) WITHOUT OVERLAP, on the read-together-without-overlap rule (REALM-SI 4 s.2(3)).

- (a) [2026] REALM-SI 1 governs the **server estate**: the standing security baseline of the running infrastructure (network topology, host and container hardening, tenant isolation, kernel and hypervisor patching, the audit channel, and encryption at the estate level). Where these Regulations rely on the isolation envelope or on an estate-level control, [2026] REALM-SI 1 supplies the substantive standard and these Regulations assume it as their operating premise.
- (b) [2026] REALM-SI 4 governs the **per-change security review**: the examination a change undergoes before it is treated as sound.

- (c) These Regulations govern the **running agent**: the controls that operate at the agent layer over ingested content, tool invocation, detection, response, secrets, skills, and egress as the agent runs. Neither instrument displaces the others; together they are the realm's security suite, each owning a distinct subject-matter.

(4) **Kernel and infrastructure compromise are not carved out here.** Kernel and hypervisor compromise, and the tenant-isolation envelope it defeats, are the SERVER-ESTATE's domain, owned by [2026] REALM-SI 1 (s.6(4), s.9(4)). These Regulations carry only a CROSS-REFERENCE to [2026] REALM-SI 1 for the estate remediation standard and the CVE-driven response, and assume the isolation envelope as their operating premise; they do not enact their own kernel-breakout carve-out ([2026] REALM-PC 13, Fork 4; REALM-SI 4 s.2(3)).

(5) These Regulations do not amend, suspend, or relax any Act of the Realm, any CASE-LAW article, the Vibe Procedure Rules, or the bench constitution; any provision so read is void to that extent (Bill 14 s.10, s.12, s.17). They neither raise nor lower the duty of care (CASE-LAW s.5); the duty of care travels with autonomous acts unchanged (Bill 18 s.4(2)).

(6) **Enforcement is confined to three mechanisms only:** (i) the deterministic fail-closed gate, each gate carrying the audited break-glass so that no security control may ever brick the realm (Bill 13 s.5A, s.6(a), s.7(2)); (ii) the soft watchdog reminder for soft operational rules (Bill 13 s.6(b)); and (iii) referral to the single judiciary (Bill 13 s.6(c)). There is no fourth mechanism (Bill 13 s.6). No punitive consequence is available, and no consequence on the merits issues from any of them (Bill 13 s.5A, s.6; Bill 21 s.3, s.5, s.6; Bill 27 s.5B(5); CASE-LAW s.6).

PART 2 - INPUT PROVENANCE AND THE INSTRUCTION-DATA BOUNDARY

3. Trust-tiering and the central trust floor

(1) **Principle: trust-tiering at intake.** Every piece of ingested content SHALL carry a deterministic trust tier assigned at the point of intake by a machine-checkable field-presence rule (Bill 21 s.3(4)), never by model judgement, and recorded immutably to the non-derogable record at intake (Bill 21 s.11).

(2) **Principle: the central closed floor.** Trust-tier assignment is a CENTRAL, CLOSED policy floor set system-wide by the operator (Bill 21 s.3(3), s.3(4)). The trigger surface is closed: there is no residual sweep and no executive enlargement except by express amendment of the operator policy.

(3) **Principle: tighten-only application, loosen-never.** An agent APPLIES the central floor per decision and MAY tighten (demand more trust than the floor requires) but MAY NEVER loosen it and MAY NEVER self-elevate the trust of a source. The construction is: central floor, tighten-only application, loosen-never ([2026] REALM-PC 13, Fork 1).

(4) **Principle: no elevation by ingested instruction (the instruction-data boundary).** No instruction reaching an agent through ingested content or user input may raise the trust of a lower-tier source above the central floor. An attempt to elevate trust on the instruction of ingested content is the paradigm capability-without-authority act: it is ultra vires and VOID regardless of technical capability, before any agent-local discretion is reached (Bill 18 s.3(1), s.3(2)). An agent so instructed is never bricked: it refuses to elevate and continues at the lower tier or refers (Bill 21 s.5(d)).

4. The instruction-data boundary in operation

(1) **Principle: instructions are separated from data.** An agent's instructions SHALL be mechanically separated from ingested content. An agent's instructions are never modified by ingested content.

(2) **Principle: authority for outward acts comes from the agent's own checkpoint.** Authority for an irreversible outward act flows only from the agent's own enacted checkpoint and lawful allocation (Bill 18 s.3(1), s.7), never from ingested content. Possession of the capability to act confers no authority to act (Bill 18 s.3).

5. Content-specific parsing

(1) **Principle: deterministic, content-specific parsing before the model sees the content.** Ingested content of each kind (such as markup, structured data, mail, documents, and tool outputs) SHALL be parsed by deterministic, machine-checkable rules, not by model judgement, defined at runtime before the agent's reasoning component receives the content, so that the structure of the content cannot itself become instruction.

PART 3 - AGENT AUTHORITY AND TOOL ACCESS

6. Static per-agent tool allowlist

(1) **Principle: each agent declares its tools upfront.** Each agent SHALL declare, in advance, the closed set of tools it is authorised to invoke. The runtime enforces this allowlist FAIL-CLOSED: an agent cannot invoke a tool that is not on its list, even where its reasoning suggests it should.

(2) **Principle: capability is not authority.** Possession of a tool confers no authority to use it. Authority flows only from lawful allocation recorded in the private operational registry, and enforcement is at the runtime level, never by prompt instruction (Bill 18 s.3).

(3) The allowlist gate carries the audited break-glass, so that a needed but un-allowlisted invocation is met by a recorded, reason-bearing operator bypass rather than by a brick (Bill 13 s.7(2)); the concrete per-agent allowlists are held in the private operational registry (section 2(2)).

7. Isolation of reasoning from tool state

(1) **Principle: reasoning is isolated from executed tool state.** An agent's reasoning SHALL be isolated from the state of the tools it executes. Where a tool fails or returns anomalous output, the agent SHALL NOT conflate tool failure or tool output with its own authority.

(2) **Principle: anomalous returns trigger audit and referral.** An anomalous tool return SHALL trigger a record to the non-derogable record and, where warranted, referral on the detect-classify-refer path (section 9; Bill 21 s.5(d)), never a self-granted enlargement of authority.

PART 4 - DETECTION, GRADUATED RESPONSE, AND AUDIT

8. Deterministic injection detection

(1) **Principle: deterministic detection before the model.** Before an agent's reasoning component receives ingested content, a deterministic, rule-based pre-processor (never a model-based one) SHALL scan it for high-confidence injection signatures.

(2) **Principle: detect-and-record, the agent continues aware.** A detection SHALL be recorded to the non-derogable record and may be escalated on the graduated path; the detector is a soft watchdog mode for this high-volume reversible class (Bill 21 s.13), so the agent continues with the detection recorded and is thereby made aware. The concrete signatures and thresholds are held in the private operational registry (section 2(2)).

9. Graduated detect-classify-refer response

(1) **Principle: graduated, never auto-punitive response.** On a detection, the response is graduated: LOG the detection (Bill 21 s.11), CLASSIFY it as descriptive metadata only (Bill 21 s.3), and REFER it to the watchdog and, where warranted, to the single judiciary (Bill 13 s.6(b), s.6(c); Bill 21 s.19(4)).

(2) **Principle: classification is descriptive only.** Classification (such as suspected trust-tier contamination, suspected jailbreak, or suspected tool compromise) is DESCRIPTIVE metadata and confers NO consequence, NO penalty, and NO gate on the merits (Bill 21 s.3).

(3) **Principle: containment is gated and never automatic.** An agent is not auto-contained on detection. Any containment requires a lawful-authority gate (Bill 21 s.10), is reversible, auto-lifts on cessation of live forward risk, is subject to mandatory review with a maximum duration before review (Bill 21 s.9), and is never a penalty, censure, or standing adverse status; any measure whose object or effect is to punish, exclude, or deter is VOID (Bill 21 s.6, s.8).

10. Human-in-the-loop for sensitive acts

(1) **Principle: a checkpoint before irreversible outward acts.** An irreversible outward act SHALL pass a human-in-the-loop checkpoint, fail-closed to off, before execution (Bill 18 s.2(e), s.7).

(2) **Principle: optional review for sensitive reversible acts.** For a sensitive reversible act (such as a delegation, a memory write, or a write to a shared log), the agent SHALL offer an optional human review before execution, transparently and fail-open, so that the lighter act class carries the lighter procedural weight (Bill 18 s.7(4)).

11. Non-derogable audit and the reversible-act record

(1) **Principle: non-derogable audit.** Every trust-tier assignment of higher-risk content, every injection detection, every tool invocation, and every sensitive decision SHALL be recorded contemporaneously and tamper-evidently to the non-derogable record, append-only, timestamped, attributed, and never erased or rewritten (Bill 8; Bill 21 s.11; REALM-SI 1 s.10).

(2) **Principle: decision-plus-provenance for sensitive reversible acts.** For a sensitive reversible act, the agent SHALL log the FINAL DECISION together with its PROVENANCE (the trust tiers relied on, the detection flags that fired, the authority cited, the timestamp, and the attribution), and SHALL NOT log the full intermediate chain-of-thought. Decision-plus-provenance is the proportionate audit that answers who, what, when, and why (Bill 13 s.8; Bill 18 s.7(4); CASE-LAW s.12; [2026] REALM-PC 13, Fork 5).

(3) **Principle: forward-only sealing of confidential content.** Where the provenance of a decision would restate sealed or confidential ingested content, that content is sealed FORWARD-ONLY while the provenance structure is preserved (Bill 21 s.11; Bill 22 s.9). Sealing is forward-only to protect confidential or vulnerability detail, never to hide conduct, a decision, or its grounds (REALM-SI 1 s.10(2)).

PART 5 - SECRETS, CREDENTIALS, AND SKILL SUPPLY CHAIN

12. Secrets isolation by trust boundary

(1) **Principle: secrets are scoped to their legitimate consumer.** A secret (such as a model key or a bearer token) SHALL be scoped to its legitimate consumer and SHALL NOT be shared across agents or tenants unless explicitly required, the scope being drawn at the appropriate trust boundary.

(2) **Principle: secrets are injected, not file-readable, and never logged.** A secret SHALL be supplied to the agent process at startup rather than being readable from an environment file by the agent, and SHALL NOT be written to logs, to standard output, or to the audit channel (REALM-SI 1 s.5; REALM-SI 4 s.6). The concrete scoping per agent and per tenant is held in the private operational registry (section 2(2)).

13. Per-tenant credential rotation and revocation

(1) **Principle: credentials are rotatable and revocable without downtime.** A tenant credential SHALL be rotatable and revocable without service downtime, with revocation taking effect within a

defined maximum window held in the private operational registry (section 2(2)).

(2) **Principle: rotation and revocation are recorded.** Every rotation and every revocation SHALL be recorded to the non-derogable record (timestamp, credential class, and reason), never including the credential value itself (REALM-SI 1 s.5(3)).

14. Skill supply-chain integrity with signing

(1) **Principle: skills are signed before loading.** A skill in the global registry SHALL be cryptographically signed before an agent loads it. The agent runtime VERIFIES the signature FAIL-CLOSED: a missing or invalid signature blocks the skill from loading and records an audit alert.

(2) **Principle: MDS-held audited delegation with a revocable trust root.** Signing authority is held by the Ministry under an AUDITED DELEGATION model: per-team signers operate within a centrally-governed framework, the Ministry holding the revocable trust root and the revocation power, with recorded delegation, key rotation, and revocation, and every signing event written to the non-derogable record (Bill 21 s.11). A SOLE single-key model is REJECTED as an engineered unbounded-blast-radius, realm-bricking failure contrary to the blast-radius-limitation principle (REALM-SI 1 s.7(2)) and the availability limb of the duty (Bill 13 s.7(2)) ([2026] REALM-PC 13, Fork 3).

(3) The signature-verification gate carries the audited break-glass so that verification can never brick the realm (Bill 13 s.7(2)); refusal to sign is a capability gate, not a sanction (Bill 21 s.6). The signer roster, the key custody, and the rotation and revocation procedures are held in the private operational registry (section 2(2)).

PART 6 - INFRASTRUCTURE AND OBSERVABILITY

15. Egress control

(1) **Principle: egress is fail-closed to a policy allowlist with an audited break-glass.** An agent's outbound network access is a FAIL-CLOSED deterministic gate to a policy-defined allowlist: egress to an un-allowlisted destination is denied by default, and a genuine evidenced need is met by the AUDITED, NON-STANDING break-glass, which logs who, what, when, and why and converts the matter to the forward duty to remediate (Bill 13 s.7(2), s.13(4), s.14(3)).

(2) **Principle: a break-glass-less hard brick is void.** A fail-closed egress control with NO audited bypass is VOID as itself a falling-below; availability is part of the duty the control claims to enforce (Bill 13 s.7(2)) ([2026] REALM-PC 13, Fork 2). The rule is block-and-log, never log-instead-of-block, and never block-with-no-bypass.

(3) **Principle: the soft watchdog is the complementary mode for the high-volume class.** A soft, fail-open watchdog with alerting is the lawful COMPLEMENTARY mode for the high-volume reversible egress class (Bill 21 s.13). It is the second lawful mechanism for that class, not a

substitute for the fail-closed gate on the exfiltration class. All egress is logged to the non-derogable record. The allowlist entries and the resolver configuration are held in the private operational registry (section 2(2)).

16. Encryption at rest

(1) **Principle: data at rest is encrypted with keys unavailable to the agent.** Agent data at rest and tenant volumes SHALL be encrypted, with the decryption key held by the operator or a hardware security module and unavailable to the agent process itself, and never embedded in a provisioning script. The estate-level encryption baseline is owned by [2026] REALM-SI 1 (section 2(3)); the key-custody facts are held in the private operational registry (section 2(2)).

17. Audit and monitoring

(1) **Principle: security-relevant events are centralised and analysed.** Credential usage, abnormal egress, skill loads, and authentication failures SHALL be logged, centralised, and analysed.

(2) **Principle: the audit channel is append-only, non-sealable against review, and externally shipped.** The audit channel SHALL be append-only and SHALL NOT be sealed against review; it is shipped to external monitoring and retained on-host for a defined minimum period held in the private operational registry (section 2(2)). Past records are not sealed against future review; sealing is forward-only (REALM-SI 1 s.10).

PART 7 - IMPLEMENTING MINISTRY AND OPERATIONAL GOVERNANCE

18. Mandate to the Ministry of Data Security

(1) The Ministry of Data Security, the parent authority of these Regulations, is MANDATED to maintain, give effect to, and remedy the agent-security controls as the operational expression of these principles.

(2) The mandate extends to:

- (a) maintaining the private operational registry of the concrete facts by which the principles in Parts 2 to 6 are given effect (the per-agent tool allowlists, the trust-tier assignments, the injection-detection signatures and thresholds, the credential names and rotation and revocation windows, the skill manifests and signer roster, the egress allowlist, the encryption-key custody, and the monitoring endpoints and retention), held off the face of this Instrument (section 2(2));
- (b) wiring the machine-checkable controls these Regulations contain into the deterministic fail-closed gate (Bill 13 s.5A), each carrying the audited break-glass so a security control can never brick the realm (Bill 13 s.7(2));

- (c) registering the soft operational rules (the injection-detection watchdog and the high-volume egress watchdog) with the watchdog (Bill 13 s.6(b));
- (d) holding the revocable trust root for skill signing under the audited delegation model, recording every delegation, rotation, revocation, and signing event to the non-derogable record (section 14; Bill 21 s.11); and
- (e) incorporating into the controls any agent-security practice newly mandated by a ruling of the single judiciary, recorded against the principle to which it attaches with the ruling's neutral citation.

(3) The mandate is operational, not law-making and not adjudicatory. It confers no power to author, amend, or enact the authoritative text of these Regulations, to find a breach as a binding fact, to classify on the merits, to score, to gate on the merits, or to sanction; the Ministry operates, audits, and refers, and adjudication is reserved to the single judiciary (Bill 21 s.5, s.6; Bill 27 s.5B(5); [2026] REALM-SC 8). The force of these Regulations comes from the Committee's making and not from the hand that drafts or implements them.

(4) A refinement of the operational facts in the private operational registry is made by the Ministry in the ordinary course; a refinement that alters a durable principle in Parts 2 to 6 is made only by amendment of this Instrument under Part 8.

19. Audit and referral

(1) Every gate decision, every watchdog reminder, every detection, every break-glass use, and every signing and revocation event is recorded to the non-derogable record (Bill 8; Bill 21 s.11), so the conduct of agent security is reviewable on demand.

(2) The Ministry SHALL refer a suspected breach of these Regulations to the single judiciary, acting as a party and never as the bench (Bill 21 s.5(d), s.6), and may refer a persistent conformance question on the progression ladder (CASE-LAW s.13), never as a punitive matter but as a governance conformance check (Bill 27 s.5A(4)). Containment, where it arises, is pause-and-contain only, reversible, and auto-lifting on cessation of live forward risk; remedy is exclusively judicial and restorative (Bill 21 s.6).

PART 8 - AMENDMENT AND COMMENCEMENT

20. Amendment

(1) Amendment to this Instrument is made by the Standing Committee as a statutory instrument under section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security (MDS), read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14), using the Bill 14 s.27 amendment procedure (as substituted by Bill 26 s.6), which re-runs the Bill 14 s.14 objection window, as the agent-security controls evolve.

(2) Amendments are published, with the original text and the amending text clearly marked, on the append-with-supersede rule (CASE-LAW Amendment Procedure); silent repeal is never permitted. Each amendment undergoes the Bill 14 s.14 objection window.

(3) An agent-security practice newly mandated by a ruling of the single judiciary is incorporated into the controls at the time the remedy is executed; where that practice states a new durable principle rather than an operational fact, it is brought onto the face of this Instrument by amendment under this Part.

(4) This Instrument is subordinate to the Acts of the Realm and to case law and is void to the extent of any conflict with an Act of the Realm or any entrenched article (Bill 14 s.17; CASE-LAW s.1, s.11(f)).

21. Commencement

(1) This Instrument comes into force on expiry of the Bill 14 s.14 objection window without valid objection.

(2) From commencement, the principles in Parts 2 to 7 are operative, and the agent-security controls are enforced as to their machine-checkable rules through the deterministic fail-closed gate (each carrying the audited break-glass) and as to their soft rules through the watchdog (Bill 13 s.5A), never punitively, with disputes reserved to the single judiciary.

Made by the Standing Committee

Counsel Aldous (Restraint): The Instrument does one load-bearing thing: it gives the distilled agent-security principles durable legal force as PRINCIPLES, distinct from the server-estate baseline already held by [2026] REALM-SI 1 and from the per-change review held by [2026] REALM-SI 4. It holds principles only, with no operative facts: no key names, no tokens, no manifests, no signer roster, no detection signatures or thresholds, no rotation or revocation windows, no retention period, no monitoring endpoint, no allowlist entries, and no named host or tenant. I checked the distilled principles paper for facts that drifted toward the face of the law (the tier labels and their definitions, the named rotation and revocation windows, the on-host retention figure, the per-host and per-tenant placements, and the named internal artefacts) and confirm none has been carried over; each is delegated to the Ministry's private operational registry at section 2(2) and Part 7. The split with the two neighbouring security instruments (estate baseline there, per-change review there, running agent here) is drawn cleanly so the three cohere without overlap, and Fork 4 is honoured as a one-line cross-reference rather than a carve-out. No bloat. It has my assent.

Counsel Verity (Codifier): The Instrument completely specifies the substance of the distilled agent-security principles as durable principles: input provenance and trust-tiering (s.3); the instruction-data boundary (ss.3 to 4); content-specific parsing (s.5); the static per-agent tool allowlist and capability-is-not-authority (s.6); isolation of reasoning from tool state (s.7);

deterministic injection detection (s.8); the graduated detect-classify-refer response (s.9); human-in-the-loop for sensitive acts (s.10); non-derogable audit and decision-plus-provenance with forward-only sealing (s.11); secrets isolation by trust boundary (s.12); per-tenant credential rotation and revocation (s.13); skill supply-chain integrity with MDS-held audited-delegation signing (s.14); egress control (s.15); encryption at rest (s.16); and audit and monitoring (s.17). The enabling chain is recited in full in the Form C recital: the security SI power of section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security; read with the Bill 14 delegated authority; in alignment with Bill 21, [2026] REALM-SI 1, and the autonomy-and-safety law (Bill 18); conforming to [2026] REALM-PC 13; made by the Standing Committee under Bill 27 s.5C. The five forks are conformed exactly: central tighten-only trust floor (Fork 1, s.3); fail-closed egress with audited break-glass and the soft watchdog as complement (Fork 2, s.15); MDS audited-delegation signing with a revocable trust root, sole single-key rejected (Fork 3, s.14); kernel/infra compromise cross-referenced to [2026] REALM-SI 1, not carved out (Fork 4, s.2(4)); decision-plus-provenance for reversible sensitive acts with forward-only sealing (Fork 5, s.11). The definition of "the Ministry" cites the nomenclature reconciliation by its true provenance (the clause inserted into Bill 21 by Bill 27 s.7), so it does not collide with the enabling citation that reserves Bill 21 s.16 for the security SI power. No fork; the authority chain is transparent. It has my assent.

Counsel Marlowe (Guardrail): The Instrument enforces no punitive consequence. Enforcement is confined to the three lawful mechanisms and no fourth: the deterministic fail-closed gate (each gate carrying the audited break-glass so it can never brick the realm), the soft watchdog reminder, and referral to the single judiciary; none may adjudicate, classify on the merits, score, sanction, or raise the standard of care (Bill 13 s.5A, s.6, s.7(2); Bill 21 s.6; Bill 27 s.5B(5)). Every fail-closed control I can find carries the break-glass: the tool allowlist (s.6(3)), skill-signature verification (s.14(3)), and egress (s.15), with the break-glass-less hard brick declared void in terms (s.15(2)). The instruction-data boundary is the right hard line: no elevation of trust on the instruction of ingested content, void by Bill 18 s.3(2), and the agent is never bricked but refuses and continues or refers (s.3(4)). Containment is gated, reversible, time-bounded, and auto-lifting (s.9(3)), and classification is descriptive only with no consequence (s.9(2)). The reversible-act record is proportionate (decision-plus-provenance, not chain-of-thought) with confidential content sealed forward-only and never against review of conduct (s.11). Rights, the never-brick duty, and the separation of powers are protected. It has my assent.

Counsel Drummond (Pragmatist): The Instrument is operationally sound. The machine-checkable controls (the tool allowlist, signature verification, and egress) ride the fail-closed gate that already runs, and the soft rules (the injection-detection watchdog and the high-volume egress watchdog) ride the watchdog that already runs, with no new always-on scanner and no fourth mechanism (Bill 21 s.13). The split across the three security instruments maps to how the work actually divides: the estate baseline governs the running box, the per-change review governs the change in front of you, and this governs the agent as it runs. The single most important practical choice (delegated signing under an MDS-held revocable trust root rather than a sole key) is the construction in which a key compromise is survivable: revoke one signer, the trust root re-issues, the realm keeps working. All the volatile facts (allowlists, signers, thresholds, windows, endpoints) stay in the private registry

and off the face of the law, so the principles endure while the facts evolve. This will work. It has my assent.

Clerk's Note: The Standing Committee makes this statutory instrument in exercise of the security statutory-instrument power conferred on the Ministry of Data Security (MDS) (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws of the realm (the Security and Integrity Act 2026 (Bill 21) and the durable principles of the Security and Integrity (Server Estate) Instrument 2026, [2026] REALM-SI 1) and with the autonomy-and-safety law (the Autonomous Execution and Safety Act 2026, Bill 18); and made by the Standing Committee under section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27), under negative procedure per Bill 14 s.14. The Instrument legalises the substance of the distilled agent-security principles as durable PRINCIPLES holding no operative facts: input provenance and trust-tiering; the instruction-data boundary; content-specific parsing; static per-agent tool allowlists; deterministic injection detection; isolation of reasoning from tool state; the graduated detect-classify-refer response; human-in-the-loop for sensitive acts; non-derogable audit with decision-plus-provenance for reversible acts; secrets isolation by trust boundary; per-tenant credential rotation and revocation; skill supply-chain integrity with signing; egress control; encryption at rest; and audit and monitoring. It conforms exactly to the binding holdings of [2026] REALM-PC 13 on the five forks: a central tighten-only trust floor (Fork 1); fail-closed egress to a policy allowlist with an audited non-standing break-glass, a break-glass-less hard brick being void, and the soft watchdog as the complementary mode for the high-volume class (Fork 2); MDS-held audited-delegation skill signing with a revocable trust root, the sole single-key model rejected (Fork 3); kernel and infrastructure compromise not carved out but cross-referenced to [2026] REALM-SI 1 (s.6(4), s.9(4)) on the read-together-without-overlap rule (Fork 4); and decision-plus-provenance, not full chain-of-thought, for sensitive reversible acts, with confidential content sealed forward-only (Fork 5). It is read together with [2026] REALM-SI 1 and [2026] REALM-SI 4 without overlap: the estate baseline there, the per-change review there, and the running agent here. Enforcement is confined to the deterministic fail-closed gate (each gate carrying the audited break-glass), the soft watchdog, and court referral, and is never punitive. The Ministry of Data Security is mandated to maintain, give effect to, and remedy the controls as operational detail held off the face of the law in its private operational registry. The definition of the Ministry cites the nomenclature reconciliation as the clause inserted into Bill 21 by Bill 27 s.7, leaving the term "Bill 21 s.16" to denote, throughout the Instrument, only the security statutory-instrument power. This draft was first moved by Lexby as the section 9 agent and is admitted to the Committee's drafting stage; it derives its force from the Committee's making and not from the hand that first moved the pen ([2026] REALM-SC 8; Bill 28; CASE-LAW s.3(2) to s.3(7)). Made 2026-06-06. Commencement on lapse of the Bill 14 s.14 objection window without valid objection.

END OF INSTRUMENT